

Response to Reviewers — COMSI-2026-03-0087

“AEGIS: A Constitutional Governance Architecture for Autonomous AI Agents” Revision in response to the Major Revision decision of 2026-09-08.

Thank you to both reviewers and to the Editor for a thorough and constructive review. Below, Editor and reviewer comments are reproduced in *italics*, each followed by our response and a pointer to the corresponding change in the revised manuscript.

A general note before the point-by-point response: Reviewer 1’s decision-letter comment refers to an attached file, “Comments for justification.docx,” described as containing detailed justification for their five listed points. That file was not included with the decision-letter email, and we were unable to locate it in the Author Portal. We contacted the manuscript administrator (computer-ma@computer.org) on 2026-09-18 to request it. In its absence, we have addressed all five of Reviewer 1’s listed points based on their inline comments and the Editor’s consolidated summary. If the attachment surfaces additional detail, we are glad to address it in a subsequent round.

1. Technical completeness (Reviewer 1 / Editor)

“The manuscript describes a ‘normalized 0.0–1.0 score from five factors’ but never gives the formula or weighting. Given that reproducibility is a central claim of the paper, this must be specified, even in simplified or illustrative form.”

Added a new subsection, “**Risk Scoring and the Decision Pipeline**” (Section III-C), giving the full five-factor formula with defined weights, a description of each factor, and a complete worked numerical example tracing one action proposal to a final risk score and decision band. A new figure (Fig. 3) diagrams the full decision pipeline, including where risk scoring sits relative to capability resolution and policy evaluation.

“Justify the federation trust weights. The formula $T = 0.30B + 0.25H + 0.20Q + 0.15A + 0.10F$ is presented as normative with no explanation of how these coefficients were derived. Please provide justification, sensitivity analysis, or at minimum acknowledge that these are provisional/tunable parameters.”

We took the minimum-bar option the Editor offered: both the federation publisher-trust weights and the new risk-scoring weights are now explicitly labeled as provisional, deployment-tunable operational defaults not derived from formal sensitivity analysis, with calibration against production data named as future work (Section III-C, Section III-D).

“Qualify the ‘complete mediation’ claim. As written, the claim... assumes a correctly isolated deployment architecture with no out-of-band execution paths. Please state this assumption explicitly and discuss its limits in more complex (e.g., microservice) deployment topologies.”

The Saltzer–Schroeder “Complete mediation” paragraph (Section II-C) now states the isolation assumption explicitly, names the specific failure case (credentials reachable outside the Tool Proxy’s mediation in a microservice topology), and points to the Limitations section for the operational implications. The intro, “What AEGIS Is Not,” and Conclusion carry brief consistent pointers rather than repeating the full qualification.

“Define audit-failure semantics. Please clarify operationally what constitutes ‘audit logging fails’..., and describe the operational handling of retries and throughput implications in high-volume environments.”

Added a new paragraph immediately after the Governance Gateway description (Section II-D) that defines audit-failure operationally (write error, network partition, hash-chain continuity failure), specifies that the Decision Engine fails closed to DENY without internal retry, and discusses the high-throughput trade-off explicitly.

“Address scalability. Please include at least a preliminary discussion of GFN-1 behavior at scale (e.g., thousands of federated organizations) and decision latency under load, even if full empirical benchmarking remains future work.”

Added scalability discussion to the Federation Network section (Section III-D): the sub-linear per-node cost design goal, explicitly labeled as a design goal rather than a measured result, the current low-tens-of-nodes deployment scale, and the fact that thousands-of-organization behavior is unvalidated. Gateway decision-latency dependence on the cached federation-signal lookup is also stated, again labeled as architectural reasoning rather than a benchmark result. The Limitations section reiterates that no production-load performance evaluation has been run and explicitly declines to present unvalidated latency/throughput figures, giving instead the architectural reasoning behind where cost is expected to concentrate.

Reviewer 1 also listed two items not elaborated in the Editor’s consolidated summary:

“4. Capability discovery mechanism discussion”

Section III-B (Layer 2: Schema) now describes the actual mechanism: capabilities are registered declaratively at deployment time as manifests, resolved against the Capability Registry shown in Fig. 1, rather than discovered dynamically at runtime. The corresponding gap — no runtime capability-extension mechanism for highly dynamic or exploratory agents — is stated plainly in Limitations as an open problem rather than a solved one.

“5. Performance assessment placeholder”

Strengthened as described above under scalability/audit-failure: we do not present fabricated or placeholder benchmark numbers, but we do now give the architectural reasoning for where performance cost concentrates and what precedent (POLYNIX, CPS enforcement) suggests is achievable, clearly distinguished from AEGIS’s own unmeasured implementation.

2. Reviewer 2’s requests

“Clarify the main contributions and objectives more explicitly in the introduction.”

The contributions paragraph at the end of the Introduction has been tightened into a single, denser statement of the five contributions rather than five separately narrated sentences.

“Include a concrete use case, prototype, or case study to demonstrate applicability.”

The new worked example in Section III-C traces one concrete action proposal through the full risk-scoring pipeline to a specific decision, with the full factor breakdown shown.

“Reduce conceptual repetition and streamline sections for better readability.”

Trimmed restatements of the action-boundary framing in the Introduction, “What AEGIS Is Not,” and Conclusion to single pointers rather than full re-explanations; tightened several other passages for concision to make room for the new required content while keeping the manuscript within the 6000-word limit (current word count: approximately 5,880 words, body text).

“Add diagrams or visual models to help communicate the architecture more clearly.”

Added Fig. 3 (the risk-scoring/decision-pipeline diagram), a third diagram alongside the existing architecture-flow and four-layer-stack figures, specifically covering the pipeline internals that were previously described only in prose.

3. References

“Reviewer 1’s suggested additions (ReAct; recent prompt-injection surveys; the academic TRiSM variant; NIST Zero Trust Architecture) are topically relevant and should be incorporated.”

- **NIST Zero Trust Architecture (SP 800-207)** was already cited in the manuscript (ref. [10]); no change needed there.

- **ReAct** (Yao et al., arXiv:2210.03629) added as ref. [21], cited in Section II-A where the reasoning-and-acting pattern underlying modern agentic systems is introduced.
- **The academic TRiSM variant** (Raza, Sapkota et al., arXiv:2506.04133) added as ref. [22], used to give the previously uncited “TRiSM” mentions in the Related Work table and text a proper citation.
- **The prompt-injection survey** (Raza, Sapkota et al., *Sustainable Computing: Informatics and Systems*, 2026) added as ref. [23], cited in the Threat Model section where prompt injection is discussed at length.

“Reviewer 2’s suggested references (on short-text clustering, toxic comment detection, and autoencoder-based term extraction) are not topically relevant to this manuscript’s subject matter and you are not required to incorporate them.”

Per the Editor’s own guidance, these were not incorporated — they address text-analytics methods unrelated to AI agent governance architecture.

4. Presentation and framing

“I suggest removing trademark and promotional language. The ‘TM’ symbols (including in the title) and the closing tagline read as product marketing rather than academic prose.”

Removed the TM mark from the title and body. Removed the closing tagline sentence (“*Capability without constraint is not intelligence.TM*”) entirely rather than simply stripping the mark from it, since the Editor’s concern was about tone, not only the symbol.

“Distinguish external validation from self-citation. Several load-bearing technical claims... are justified by citing the author’s own unpublished specification documents (RFC-0004, GFN-1 §3.7–3.8, ATM-1) as though they were independently established standards. Please restructure these passages to make clear which claims rest on external, peer-reviewed foundations... versus the author’s own specification decisions.”

Added an explicit framing paragraph at the end of “The Reference Monitor Model” (Section II-B) naming which foundations are established, peer-reviewed external sources (Anderson 1972, Saltzer and Schroeder 1975, Schneider 2000, NIST SP 800-207) versus which are the author’s own specification decisions (AGP-1, GFN-1, ATM-1), and stating this distinction applies throughout. Added a second, local framing sentence immediately before the detailed GFN-1 trust-model material (Section III-D) reiterating that what follows is specification, not external standard.

“Reframe the ‘peer review’ and ‘independent validation’ narrative. The individuals credited with review and convergent validation (Mattijs Moens, Nathan Freestone) are described as founders of their own comparable projects. This is valuable practitioner feedback but should not be presented as formal peer review or as external validation of AEGIS’s correctness. Please reframe this section more modestly as informal design consultation.”

Renamed the subsection from “Peer Review and Specification Status” to “Design Consultation and Specification Status.” Reworded the opening sentence to describe the interaction explicitly as informal design consultation, not formal peer review. Reworded the Freestone paragraph to describe the convergence as “a signal that the action boundary is a natural point to design around,” removing the “independent external validation” and “evidence” language. Made matching edits to the Acknowledgments section, and removed the sentence there claiming Freestone’s convergence “provided external validation of AEGIS’s core architectural claims.”

“Clarify institutional framing. Given the author’s affiliation with a personal LLC and the manuscript’s function in part as specification documentation for a named initiative, please ensure the abstract, conclusion, and any claims of readiness (‘compliance-ready governance foundation’) are scoped strictly to what is demonstrated within the paper itself.”

Changed “provides a compliance-ready governance foundation for regulated deployments” (Conclusion) to “gives regulated deployments an architectural starting point for those obligations,” and added a parallel

scoping sentence to the NIST/EU AI Act alignment section (Section V) stating explicitly that the Article 14 mapping is architectural, not a claim of regulatory compliance certification, which AEGIS has not undergone.

Summary of new/changed content

- New Section III-C, “Risk Scoring and the Decision Pipeline,” with full formula, factor definitions, and worked example
- New Fig. 3 (decision-pipeline diagram)
- New audit-failure-semantics paragraph (Section II-D)
- New GFN-1 scalability/latency discussion (Section III-D)
- New capability-discovery-mechanism content (Section III-B)
- Strengthened Limitations section (complete-mediation scope, capability-extension gap, performance-evaluation status)
- Complete-mediation claim qualified with its isolation assumption (Section II-C)
- Self-citation vs. external-foundation framing added (Section II-B, III-D)
- “Peer Review” section renamed and reframed as informal design consultation; matching Acknowledgments edits
- “Compliance-ready” language replaced with scoped claims (Conclusion, Section V)
- Trademark symbols and closing tagline removed throughout
- Three new references added (ReAct, TRiSM academic variant, prompt-injection survey); NIST Zero Trust (already cited) confirmed present
- Trimmed repeated restatements of the action-boundary argument to stay within the 6000-word limit

Word count of the revised manuscript body (abstract through acknowledgments): approximately 5,880 words, within the 4000–6000-word requirement.